infra-lab: multi-account AWS platform

Terraform IaC (20 reusable modules, 36 ADRs) · GitHub Actions with keyless OIDC · AWS Organizations + Control Tower · us-east-1 (us-west-2 for replicas)

Deployed baseline
On demand / scales to zero
Defined in code, not deployed
Account IDs and hostnames omitted

DELIVERY AND ACCESS

GitHub monorepo
infra/ modules, live roots, mgmt
app/ · docs/ (ADRs, runbooks)
scripts/ · web/ (backlog)

GitHub Actions CI gates
terraform fmt / validate / plan
tflint
checkov (IaC security)
terraform-compliance
(tagging policy as code)
gitleaks secret scanning
shellcheck · markdownlint
pre-commit parity with CI (ADR-028)

assume role

OIDC federation (ADR-009)
Short-lived STS credentials
No stored AWS keys in GitHub

Engineer access
IAM Identity Center (SSO)
5 permission sets: Admin, Platform, Developer, SecurityAuditor, ReadOnly

DESIGN PRINCIPLES

- No IAM users or access keys (SCP)
- Guardrails by OU, service boundary SCPs on single-purpose accounts
- Compute off by default in dev (ADR-030); workers scale from 0
- Execution plane cannot reach the control plane except HTTPS
- Encryption with customer KMS keys
- TLS-only S3 bucket policies
- Tag-based cost allocation, budgets, anomaly alerts and backups
- Every decision recorded as an ADR

AWS ORGANIZATION

Management account
governance and state backend; the dev / staging / prod environments are defined here too (lab cost choice)

Organizations + Control Tower
Landing zone, 4 OUs
SCPs: deny IAM users, root, leaving org, disabling security services, unapproved regions
Tag and backup policies

Security services (org-wide)
CloudTrail org trail (KMS)
AWS Config aggregator + conformance pack
GuardDuty, Security Hub (CIS + FSBP), Access Analyzer

Identity
IAM Identity Center
GitHub OIDC provider + deploy role
Strict password policy
Cross-account audit role

FinOps
Org monthly budget
Cost Anomaly Detection -> SNS (customer KMS key)
Email alert subscriptions
Tag-based cost allocation

Terraform state backend
S3, versioned, KMS, TLS-only
Cross-region replica
DynamoDB state locks
Access-logged log buckets
One state key per root

WORKLOAD ENVIRONMENTS
one control-plane VPC + one execution-plane VPC per environment, joined by VPC peering

dev
VPC pair and workloads defined in code, not deployed. Live today: scheduled Lambdas and their secrets.

Control-plane VPC 10.0.0.0/20 *private subnets, no NAT*

- **ALB (blue / green)** — HTTPS :443, test :8443; CodeDeploy traffic shift
- **ECS Fargate: API** — CPU / memory autoscaling; desired count 0 (ADR-030)
- **Step Functions** — Job orchestrator; retries, X-Ray tracing
- **SQS queues + DLQs** — nano · medium · xlarge + FIFO ordered queue
- **Aurora Serverless v2 (Postgres 15)** — 0.5 to 4 ACU, auto-stop Lambda
- **S3 gateway** — endpoint

HTTPS (ECS Fargate: API -> ECS Fargate worker tiers)
jobs (SQS queues + DLQs -> ECS Fargate worker tiers)
VPC peering

Execution-plane VPC 10.0.16.0/20

- **ECS Fargate worker tiers (scale from zero)** — nano 0.25 vCPU · medium 1 vCPU · xlarge 4 vCPU; one service and one queue per tier (ADR-014, ADR-020)
- **Network ACL on private subnets** — Deny egress to all RFC 1918 ranges; Allow HTTPS to the control-plane VPC only
- **Aurora Serverless v2 (Postgres 15)** — 0.5 to 8 ACU, separate cluster
- **S3 gateway** — endpoint

- **Scheduled Lambdas** — EventBridge Scheduler: idle teardown, batch job
- **Wake endpoint** — Lambda function URL starts MemPalace
- **Secrets Manager** — Lambda secrets KMS encrypted
- **S3 evidence bucket** — KMS key, TLS-only versioned
- **CloudWatch + Backup** — dashboard, alarms, tag-based backup
- **Flow logs + budgets** — VPC flow logs per-env budgets

staging
Control VPC 10.0.32.0/20
Execution VPC 10.0.48.0/20

Same VPC-pair, NACL and endpoint code as dev. Network layer only.

prod
Control VPC 10.0.64.0/20
Execution VPC 10.0.80.0/20

Same VPC-pair, NACL and endpoint code as dev. Network layer only.

Security OU

Log Archive account
Control Tower managed
Central CloudTrail and Config logs

Audit account
Control Tower managed
Delegated admin for GuardDuty and Security Hub

Infrastructure + Sandbox OUs: guardrails attached, reserved

Workloads OU
single-purpose accounts, each with a service-boundary SCP

MemPalace account: shared MCP memory server (ADR-034) *VPC 10.0.112.0/20*

- **Route 53 + ACM** — Two hostnames; TLS certificates
- **ALB + AWS WAF** — HTTPS listener; host-header rules; bearer-token auth
- **ECS Fargate (one service per tenant)** — MemPalace server + Qdrant per task, EFS per tenant, image pinned by digest. Second tenant currently off.
- **Idle teardown and wake** — EventBridge Scheduler -> Lambda checks traffic; GitHub Actions scales to 0 after 90 min idle. Self-serve wake via Lambda function URL.
- **Ops and security** — ALB access logs -> S3 -> Glue + Athena; Customer KMS key, Secrets Manager tokens. About $35 to $40/mo running, about $1.40/mo torn down.

Workspaces account: dev desktops (ADR-031) *VPC 10.0.96.0/20*

- **Self-service API** — API Gateway -> Lambda provisioner -> DynamoDB
- **EC2 Spot desktop + NICE DCV** — Browser IDE, Docker; idle stop at 30 min
- **Ollama GPU host (ADR-033)** — dormant